FinCore Denetimi

Güncel aws sistemi var.2029 a kadar destek alıyor.SUPPORT_END="2029-06-30"
! 4 aktif kullanıcı varmış sistemde.Gereksiz kullanıcı yok denmişti ama ben denetim için geldim.Burayı bir incele belki gerekli belki gereksizdir.[ec2-user@ip-172-31-21-74 ~]$ uptime
 11:15:17 up 40 days, 3:31, 4 users,

!40 gün [ec2-user@ip-172-31-21-74 ~]$ uptime
 11:15:17 up 40 days. yani sistem 40 gündür reboot edilmemiş bir incele
!!! Test hesabı hala aktif test:x:1001:1001::/home/test:/bin/bash
! Tempconsultant hesabı aktif tempconsultant:x:1004:1004::/home/tempconsultant:/bin/bash
! intern:x:1005:1005::/home/intern:/bin/bash Stajyer hesabı aktif bunlar hala çalışıyor mu kurumda bir incele.

!!!backupsvc:x:1006:1006::/home/backupsvc:/bin/bash backup bir kullanıcı gibi bin bash'e atılmış bu hesaba biri girerse sıkıntı olur
!admin:x:1002:1002::/home/admin:/bin/bash admin hesabı gerçek bir kişiye mi bağlı yoksa kimin olduğu belli değil mi ? Accountability sorunu çıkabilir.

!!! Parola politikası yok çalıştırdığım tüm chage komutlarında password expires:never ve maximum number of days between password change 9999 yazıyor.Bir daha uğraşmamak için hepsini ayarlayıp bırakmış.

!!!tempconsultant zombi hesap.En son 1 ocak 2024 te parolası değişmiş.Sistemde unutulan hesaplar saldırganlar için en iyi backdoorlardır.

!!! Kullanıcı hesapları iş ihtiyacı doğrultusunda oluşturulmuştur deniyor ancak test ve intern hesapları canlı ortamda hala mevcut.

!!!lastlog çıktısına bakıldığında tempconsultant ve interne hiç giriş yapılmamıştır.Yıllardır değişmemiş şifresi ve hesaba da hiç girilmemiş bu ikiside potansiyel backdoordur.

!!! Ec2-user bir shared accounttur. Log silinse bir şey olsa ec2-user yaptı olarak görürüz ama hangisi yaptı ? farklı iplerden bir sürü giriş olmuş

!!! User test may run the following commands on ip-172-31-21-74:
    (ALL) NOPASSWD: ALL
Test hesabı parolaya tabi değil istediği gibi root olabilir ve bu hesap 2024 ten itibaren. Hiç parola değişikliği almamış.Ayrıca test hesabı full yetkiyle açık halde bekliyor.

!!! [ec2-user@ip-172-31-21-74 ~]$ sudo grep ClientAlive /etc/ssh/sshd_config
#ClientAliveInterval 0
#ClientAliveCountMax 3
yorum satırıdır ve sistemde olan 4 kişi hala timeout yememiştir.Bu yorum satırı olmasaydı otomatik olarak o oturumlar kapatılacaktır.Session Timeout Zafiyeti.

!!! bir yönetici ftpyi açıp unutmuş olabilir.önceki loglarda bunun baktığını görmüştük.FTP'yi açıp bırakmışlar FTP direk açık metin olarak göndereceği için(şifreler ve veriler) man in the middle saldırısı ile şifreler saniyeler içinde çalınabilir.
Ayrıca bu ftp enabled olarak ayarlandığı için reboottan sonra da çalışacaktır.Çok büyük bir sıkıntı vsftpd.service - Vsftpd ftp daemon
     Loaded: loaded (/usr/lib/systemd/system/vsftpd.service; enabled;

!!! Auditd logları disabled olarak ayarlanmış.Sistem ilk aldığı rebootta log tutucuları kapalı olarak başlayacak.Ya aşırı özensiz bir ekip var ya da içeride birisi var diye düşünmeye başladım artık. auditd.service - Security Auditing Service
     Loaded: loaded (/usr/lib/systemd/system/auditd.service; disabled;

!!! Defense in Depth diye bir kural vardır.AWS güvenliğine güvenip bir firewall kurulmamış sisteme.Saldırgan awsyi aşarsa veya bir admin aws panelinde portları internete açarsa ne yapılır ? Tamamen dışarıya güvenmek büyük bir eksiklik.Firewall kurulmalı.Açık servisler (FTP) direk saldırılara maruz kalacak.SUNUCU GÜVENLİK DUVARI YOK

!!!tcp6   0   0 :::21   :::*   LISTEN   11 ftp sunucusu internete açık.firewallda yok .birisi deneyip parolaları ele geçirebilir.
Port 8* yerine port 443 yani şifreli ve daha güvenli bir port tercih edilebilirdi.

!!! Sunucu 1 aydan itibaren gelen hiçbir patchi almamış ve sunucu güncel tutulmamış.Reboot edilmediği için sistem.Gelen çekirdek güncellemeleri de aktif değil.

!!! World writable dosyalarda auditlab müşteri verisi
Finans maaşlar finansal veriler
Veritabanı
Yedekler (AWS cloudu ele geçirebilirler)
İk personel bilgileri (Kvkk)
Backup müşteriler sql (yedekler)
Paylaşım yönetim primleri (yönetim kurulu primi)
Hepsi DEĞİŞTİRİLEBİLİR veya SİLİNEBİLİR.Okunması bile uygun olmayan bu şeylerin world writable olması hiç uygun değil.CIA üçgeni mahvolmuş durumda.

!!! Root kendisi bu dosyaları koymuştur.Bu hassas dosyaları 600 gibi bir yetkiyle koruması beklenirken hepsine 777 vermiş veya korumayı ihmal etmiş.sistemden silinmeyen tempconsultant hesabı ele geçirildiği takdirde bunların hepsini değiştirme ve silme yetkisi de olacaktır.Büyük risk